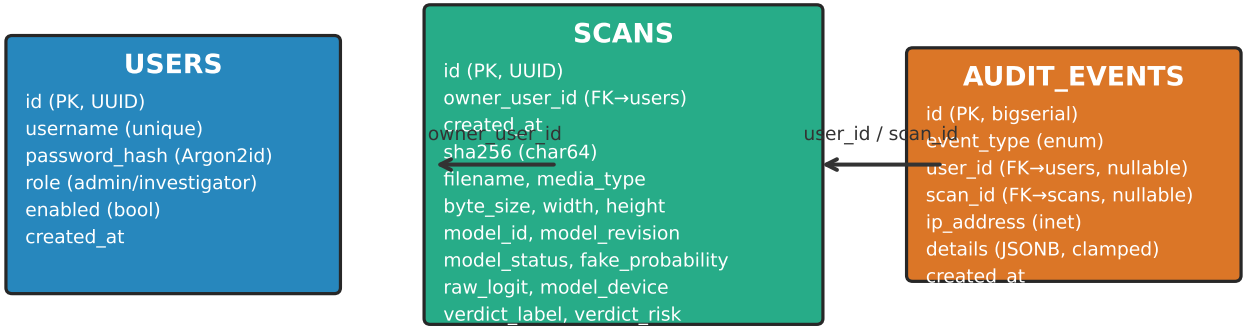
USERS
id (PK, UUID)
username (unique)
password_hash (Argon2id)
role (admin/investigator)
enabled (bool)
created_at
SCANS
id (PK, UUID)
owner_user_id (FK→users)
created_at
sha256 (char64)
filename, media_type
byte_size, width, height
model_id, model_revision
model_status, fake_probability
raw_logit, model_device
verdict_label, verdict_risk
owner_user_id
AUDIT_EVENTS
id (PK, bigserial)
event_type (enum)
user_id (FK→users, nullable)
scan_id (FK→scans, nullable)
ip_address (inet)
details (JSONB, clamped)
created_at
user_id / scan_id
Authentication Boundary: JWT (HS256, 30-min) → HttpOnly Cookie + Bearer
CSRF: Origin validation on state-changing endpoints
Rate Limits: login 5/min/peer, scans 10/min, default 120/min (in-memory, per-process)